SOC Analyst – Phishing Investigation Questions

-Anjali Saini

1. How was the Phishing Email Detected?

- Suspicious URL redirect:-

  (hxxps://intranet.hr-portal.com/secure-policy-update)

  ↓

  (https://www.evil.com/)

- No email authentication (SPF/DKIM/DMARC failures)
- Urgent tone with false deadline.
- Malicious [.py] executable attachment.

2. Who are the recipients of the phishing email?

- 23csu241@ncuindia.edu
- 23csu238@ncuindia.edu
- 23csu036@ncuindia.edu
- 23csu155@ncuindia.edu
- 23csu156@ncuindia.edu
- 23csu086@ncuindia.edu
- 23csu210@ncuindia.edu

3. What is the sender's email address and domain?

- **Sender:** 23csu141@ncuindia.edu
- **Domain Name:** NCUINDIA.EDU
- **Display Name:** Jatin Singh
- **Reply-to domain mismatch:** secure-outlook-mail.com(found in URL analysis).

4. Does the email contain malicious indicators?

Malicious indicators in the email:-

- **URL Redirect** – Confirmed malicious domain.
- **Malicious Attachment:** help.pdf.py [python script]
- **Decoy Attachment:** help.pdf [likely clean PDF as lure]
- **No Email Authentication:** SPF/DKIM/DMARC all missing.
- **Urgency:** "Suspension of account access" threat.

- **Date Deadline:** Deadline passed (Aug10,2025) before send date (Oct 30.2025).

5. **Has any user clicked the link or opened the attachment?**
   - **URL Clicks:** Unknown – check proxy logs for www.evil.com access.
   - **EDR** – Process creation events for the attachment, File execution of [.py] extensions.
   - **Email Security Gateway** – Verify if any users clicked attachment or macros in PDF.

6. **Were any credentials entered or files downloaded?**
   - Check for Network logs -> DNS Logs, Firewall Logs.
   - Endpoint Investigation -> File System Analysis, Registry Analysis and Memory Analysis. Check for python scripts or Powershell commands.
   - Check for Credential Theft Indicators.
   - Check for File Download Indicators.

7. **What is the reputation of URL, IP, and attachment hash?**

   URLs:

   - `https://www.evil.com/` – Malicious {Virus-Total Result}
   - `http://secure-outlook-mail.com/` – Not Malicious

   Attachments:

   - `help.pdf.py` - Malicious (SHA256: `137b0742721d86aaab45befe0591ba4878c57c6bed58a136e1959c53ef06941`)
   - `help.pdf` – Not Malicious (SHA256: `6dab6175413962b719c38e4678e45a5d1c4084be676ea102b960f8b648fb0bc60`)

   Email Auth: Complete failure (SPF/DKIM/DMARC = None)

8. **Is there any evidence of lateral movement or post-exploitation activity?**
   No current evidence found.
   - Find for EDR alerts, abnormal authentication attempts, internal scanning or command and control communication, PowerShell, Python or scheduled task creation exists in network.
   - Monitor SIEM for unusual login patterns and new service creation or registry persistence.
   - Review EDR logs for execution of attachment or child process spawned by python interpreters.
   - Inspect Firewall and DNS Logs for repeated connections to known malicious domains/IPs.

9. Have similar phishing emails been seen previously?

Investigation Approach:-

- Query SIEM for Reuse of malicious URLs, matching attachment hashes or file names and similar email subjects.
- Review Email Security Gateway logs for Historical emails from the same domain or display name or Previous SPF/DKIM/DMARC failures.
- Check Threat Intelligence feeds for known phishing campaigns leveraging Python-based payloads.

10. What containment and remediation actions are required?

Immediate Actions:

- Block URLs: www.evil.com, intranet.hr-portal.com
- Quarantine email from all inboxes.
- Disable sender account: 23csu141@ncuindia.edu (likely compromised)
- Alert recipients – Do not interact
- Scan endpoints for IOCs

Forensic Actions:

- Analyze .py file: Sandbox help.pdf.py (SHA256 provided)
- Check PDF: Verify help.pdf for embedded malicious content
- Review Logs:
  - Proxy: Access to malicious URLs.
  - EDR: .py file execution.
  - Authentication: Compromised Accounts.

Remediation:

- Reset passwords for any clicked/engaged users.
- User awareness training – HR-themed phishing.
- Update email filters to block executable attachments.
- If .py is malicious and executable isolate the endpoint, check for C2 traffic to evil.com.